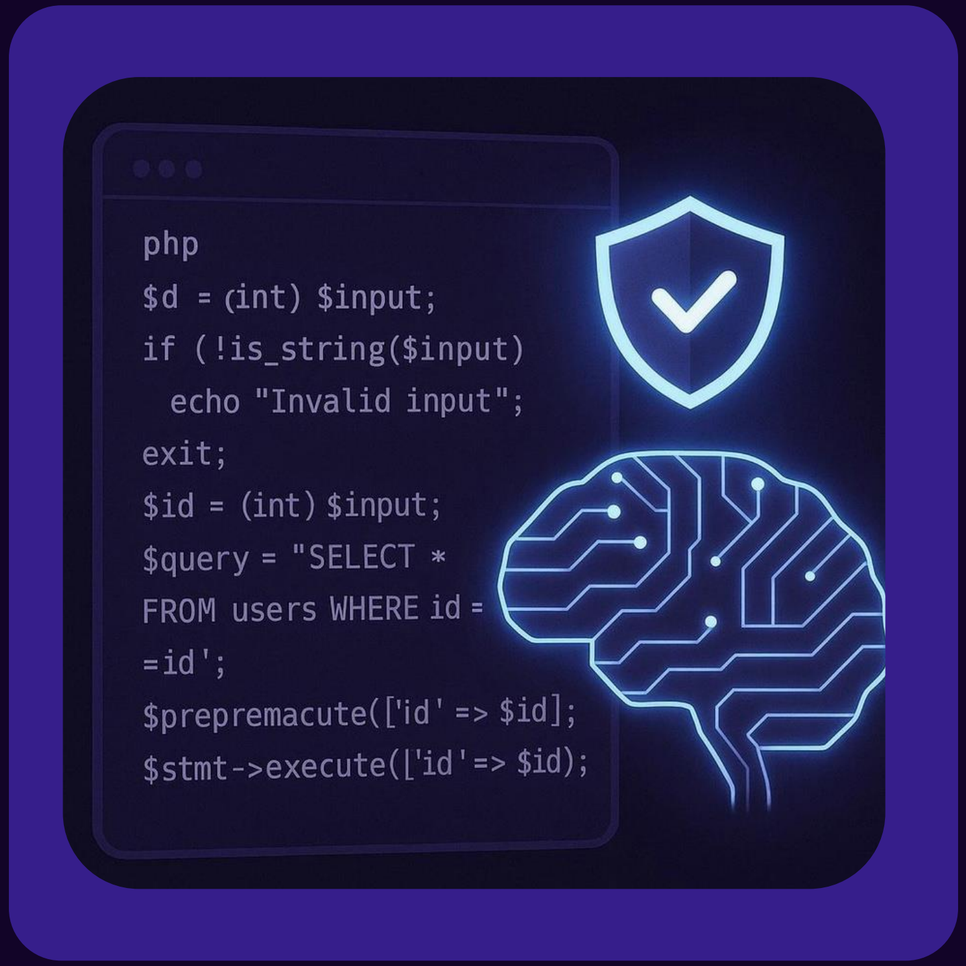
NEURO AUDIT

AI Secure Code Reviewer



MEET OUR TEAM

Yassen Ahmed
20211047

Youssef Hazem
20211071

Mohamed Ahmed
20210739

Maria Safwat
20210708

Mazen Ahmed
20210714

Mohamed Ahmed
20210736

Supervised by:

Dr. Amr S. Ghoneim

June 2025

INTRODUCTION

More than 79.2% of websites are built with PHP, such as Facebook, Wikipedia, and Spotify.

However, PHP remains vulnerable to serious threats like SQLi and XSS.

Manual source code review time-consuming and costly.

By increasing CI/CD, there became a necessity for automated vulnerability detection.

PROBLEM STATEMENT

- Static analysis tools have the highest FPR.
- Every 39 seconds, a cyberattack occurs.
- From 2015 to 2025, 10,675 SQLi and 31,500 XSS vulnerabilities were detected by the Common Vulnerabilities and Exposures (CVE) database.

RELATED WORK

1 **Static Analysis tools**

such as **SonarQube & GitLab SAST**
custom pattern matching include PHP vulnerability rules
(OWASP Top 10, CWE checks)

2 **TAP**

3 **VulEye**

same evaluation dataset from SQLi-LAB
BUT used GNN (Graph Convolutional Network (GCN))

RELATED WORK

4 VulHunter

- Depends on similarity
- Searching Exploit Points → Generate CFG and DFG → Bytecode → BiLSTM (receive two inputs and produce one output)

Approaches or tools	P(%)	R(%)	F1(%)	FPR(%)	FNR(%)
SQL-SET					
RIPS	13.60	95.65	23.16	69.88	4.35
Sonarqube	12.98	40.22	19.62	31.00	59.78
Phpcs-security-audit	10.60	97.83	19.13	94.88	2.17
VulDeePecker	**86.02**	86.96	86.86	**1.63**	13.04
VulHunter	78.63	**100.0**	**88.04**	3.13	**0.00**
XSS-SET					
RIPS	43.51	97.71	60.21	96.51	2.29
Sonarqube	41.79	43.81	42.78	46.42	56.19
Phpcs-security-audit	42.06	95.41	58.39	100.0	4.59
VulDeePecker	90.04	**97.25**	93.51	8.19	**2.75**
VulHunter	**99.02**	92.22	**95.50**	**0.70**	7.78
MIX-SET					
RIPS	31.42	75.78	44.41	63.58	24.22
Sonarqube	24.44	62.12	35.08	73.85	37.88
Phpcs-security-audit	29.89	94.70	45.43	85.43	5.30
VulDeePecker	76.43	95.47	84.89	8.19	4.53
VulHunter	**85.76**	**97.99**	**91.44**	**6.26**	**2.01**

RELATED WORK

SQLi

Approach	Precision	Recall	F1-Score	FPR	FNR
VulHunter	79%	100%	88%	3%	0%
NeuroAudit (on the same dataset)	87%	100%	93%	2%	0%

RELATED WORK

XSS

Approach	Precision	Recall	F1-Score	FPR	FNR
VulHunter	**99%**	92%	**96%**	**0.7%**	8%
NeuroAudit (on the same dataset)	86%	**96%**	91%	11%	**4%**

RELATED WORK

SQLi & XSS

Approach	Precision	Recall	F1-Score	FPR	FNR
VulHunter	86%	98%	91%	6%	2%
NeuroAudit (on the same dataset)	92%	99%	95%	1%	1%

DATASET

1. PHP Vulnerability Test Suite (2015)
2. PHP Test Suite – XSS, SQLi 1.0.0 (2022)
3. SQLI-LABS: 69 samples
4. Custom Dataset: from GitHub and Exploit DB

METHODOLOGY

AST representation

Associates semantic token names.
provide a comprehensive representation

Keras Tokenizer and Embedding

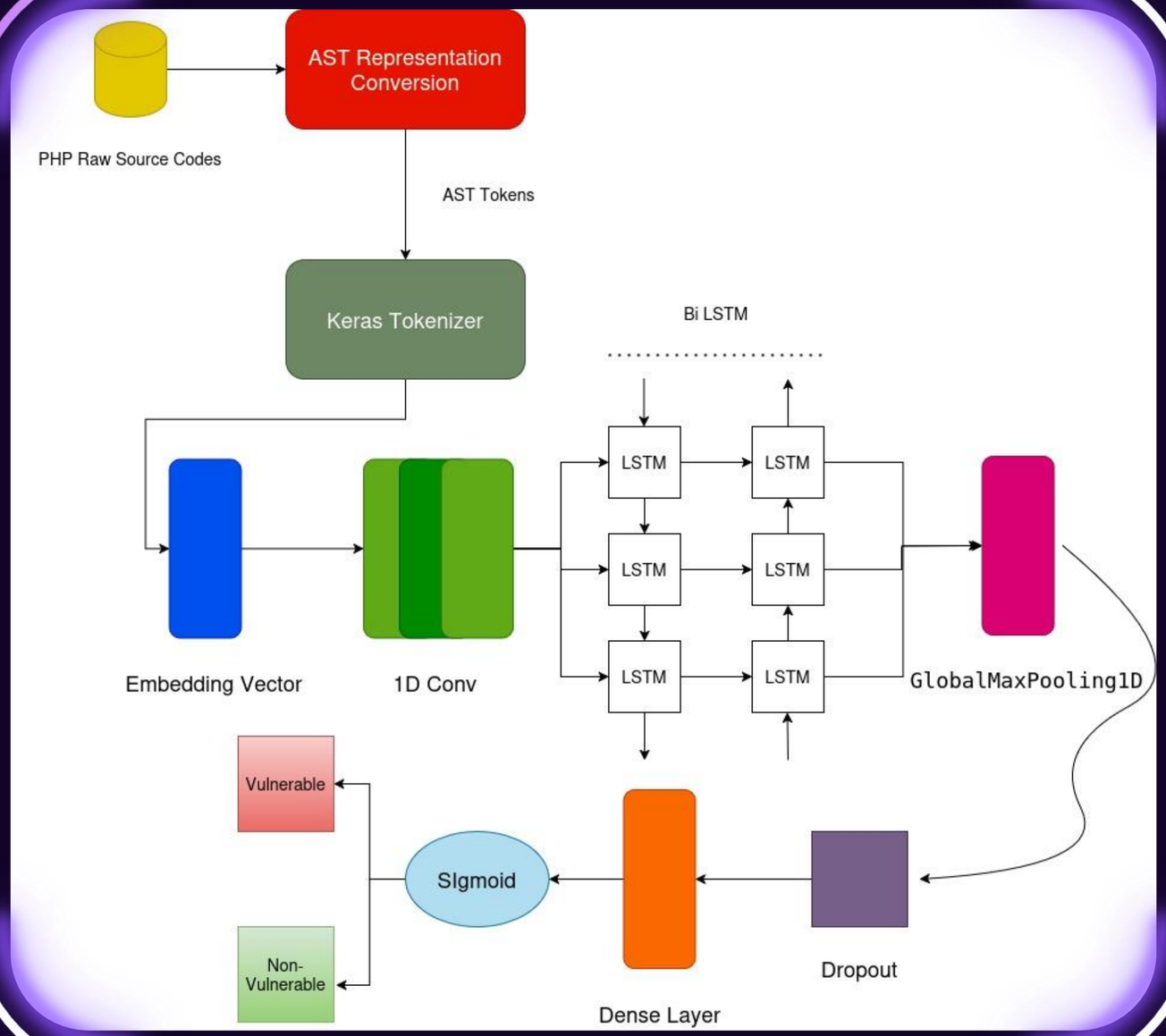
Mapping then transformed into dense vector representations

3 models

1.SQLi Classifier.
2.XSS Classifier.
3.Multi-class Classifier.

MODEL ARCHITECTURE

HYBRID LEARNING MODEL (CNN & BILSTM)

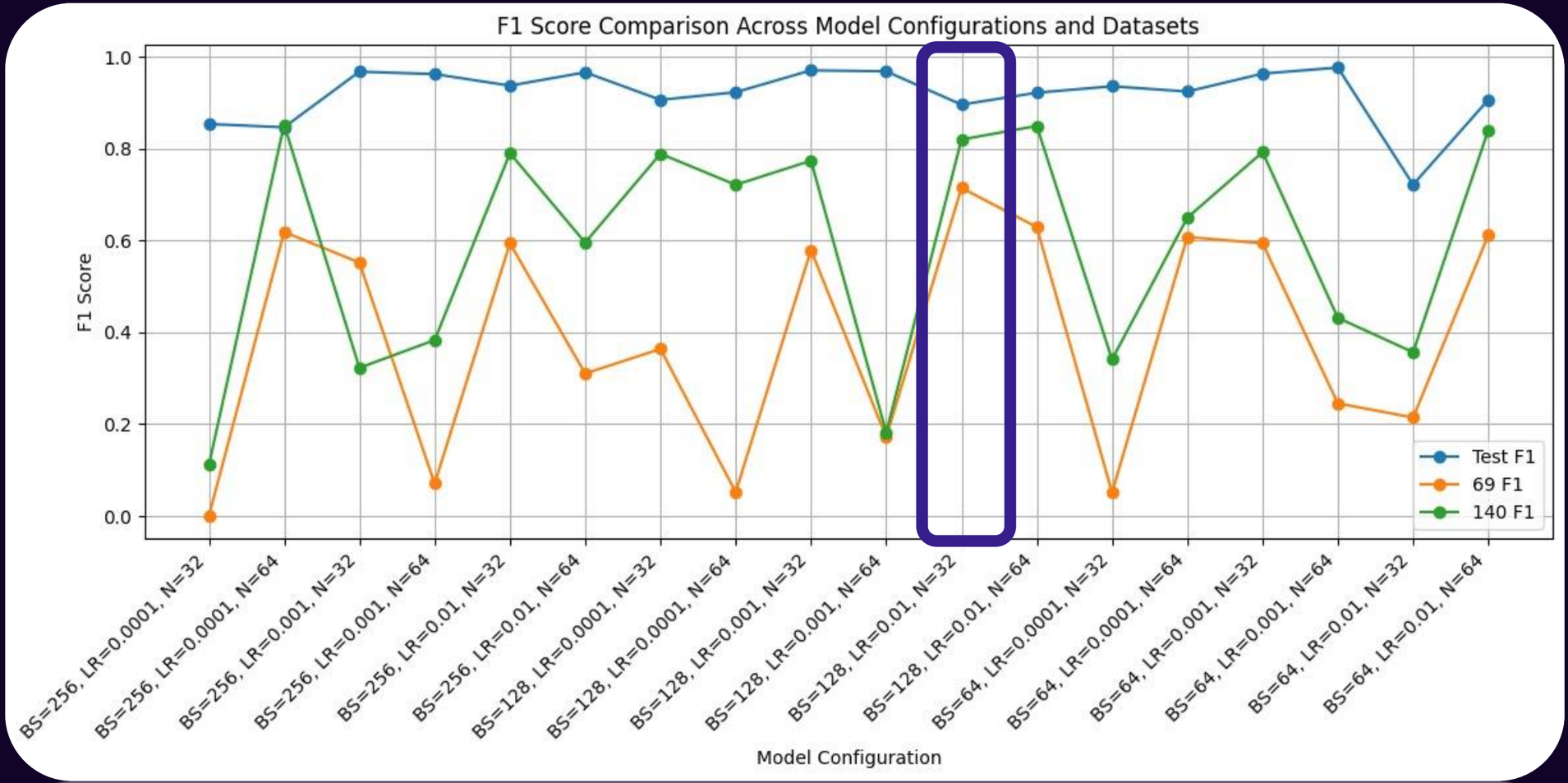


MODEL ARCHITECTURE

Grid Search

	Batch Size	LR	Neurons	Test Acc	Test F1	Test Loss	69 Acc	69 F1	69 Loss	140 Acc	140 F1	140 Loss
0	256	0.0001	32	0.942716	0.853351	0.148343	0.437956	0.000000	1.728505	0.314286	0.111111	1.328062
1	256	0.0001	64	0.935900	0.846181	0.156010	0.540146	0.618182	0.939221	0.771429	0.851852	0.557010
2	256	0.0010	32	0.986585	0.967297	0.043154	0.525547	0.551724	1.829781	0.400000	0.322581	2.314865
3	256	0.0010	64	0.984809	0.961968	0.035563	0.423358	0.070588	2.420525	0.378571	0.382979	1.948853
4	256	0.0100	32	0.974331	0.936820	0.064976	0.540146	0.593548	4.652956	0.707143	0.789744	2.506711
5	256	0.0100	64	0.985715	0.965840	0.033452	0.416058	0.310345	4.332488	0.514286	0.595238	2.884881
6	128	0.0001	32	0.962367	0.905893	0.104696	0.540146	0.363636	0.913788	0.735714	0.788571	0.487889
7	128	0.0001	64	0.968385	0.922503	0.074533	0.467153	0.051948	2.600781	0.657143	0.720930	1.304274
8	128	0.0010	32	0.987492	0.970174	0.027057	0.532847	0.578947	2.341009	0.707143	0.773481	1.378687
9	128	0.0010	64	0.986875	0.967987	0.030911	0.437956	0.172043	2.623924	0.292857	0.181818	2.475501
10	128	0.0100	32	0.953049	0.895506	0.113884	0.708029	0.714286	2.664279	0.735714	0.819512	1.712639
11	128	0.0100	64	0.965811	0.921436	0.069802	0.569343	0.628931	3.597943	0.771429	0.849057	1.752998
12	64	0.0001	32	0.974875	0.935469	0.068498	0.459854	0.051282	1.712540	0.364286	0.340741	1.753014
13	64	0.0001	64	0.967950	0.923977	0.083507	0.613139	0.607407	1.129567	0.614286	0.649351	0.816362
14	64	0.0010	32	0.985135	0.962976	0.035252	0.540146	0.593548	1.867483	0.700000	0.792079	1.800706
15	64	0.0010	64	0.990247	0.976138	0.020349	0.416058	0.245283	2.219247	0.378571	0.431373	1.901664
16	64	0.0100	32	0.908056	0.721257	0.158676	0.518248	0.214286	2.288344	0.407143	0.356589	1.373133
17	64	0.0100	64	0.959684	0.906208	0.094621	0.554745	0.611465	3.726911	0.750000	0.840183	0.993856

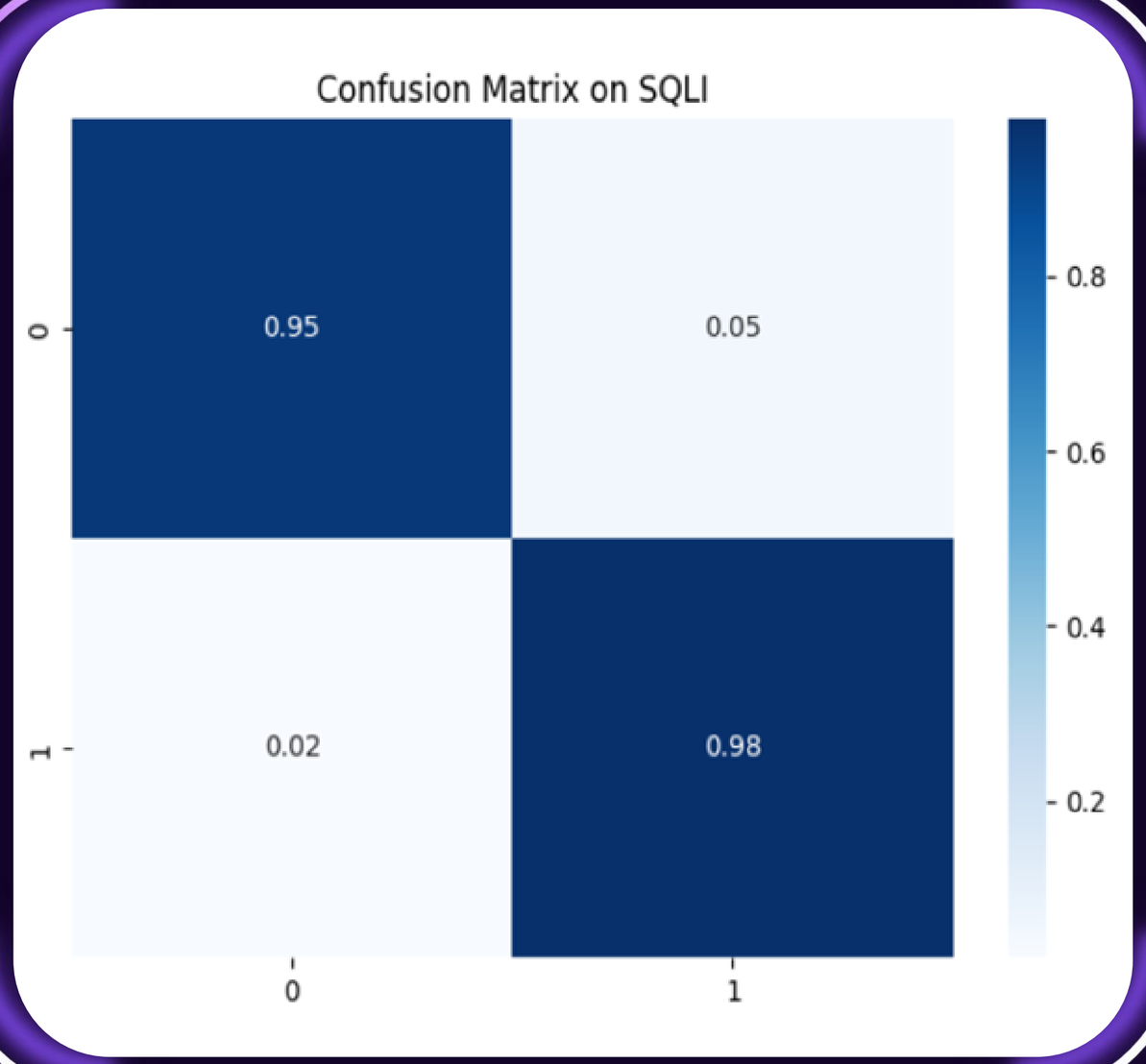
MODEL ARCHITECTURE



RESULTS SQLI

Evaluation Set	Accuracy	Precision	Recall	F1-Score	Loss
Train	95%	83%	98%	90%	0.11
Test	95%	82%	98%	90%	0.11
NeuroAudit's custom dataset	74%	79%	85%	82%	1.7
SQLi-LAB	72%	70%	72%	71%	2.66

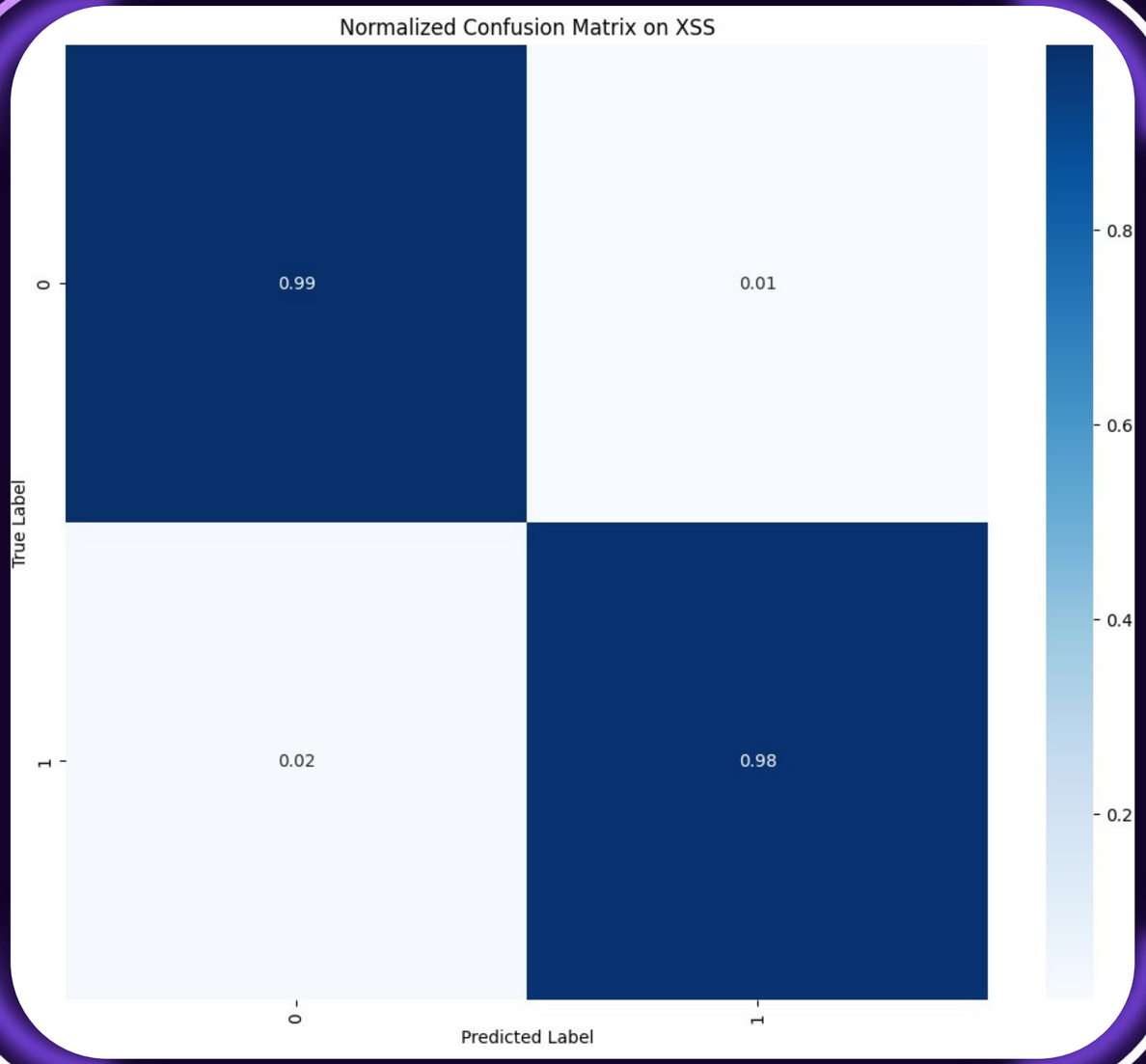
RESULTS



RESULTS XSS

Evaluation Set	Accuracy	Precision	Recall	F1-Score	Loss
Train	99%	95%	98%	97%	0.018
Validation	99%	95%	98%	96%	0.02
Test	99%	95%	98%	96%	0.02

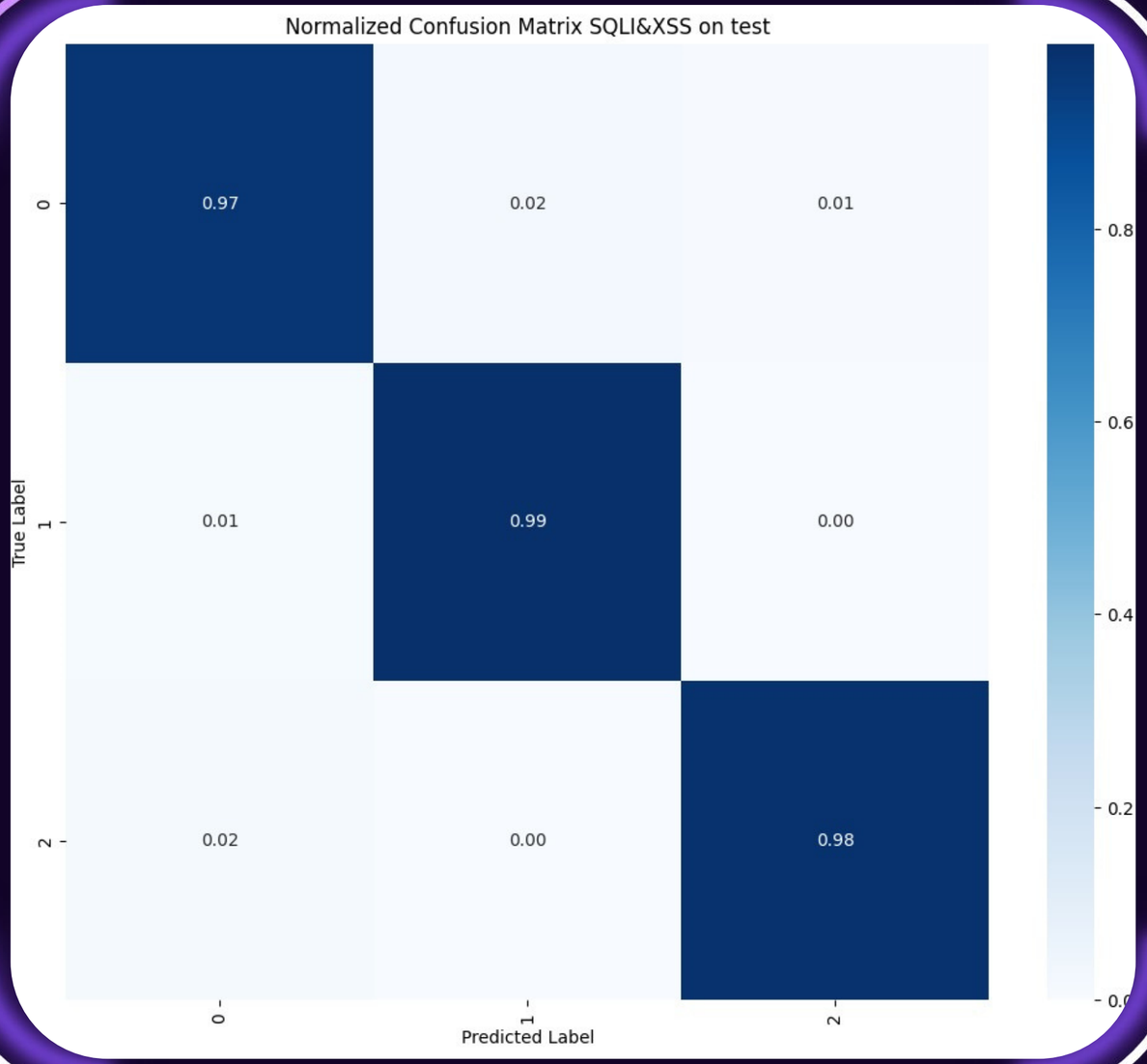
RESULTS


Normalized Confusion Matrix on XSS
0.99
0.01
0.02
0.98
True Label
Predicted Label
0
1
0
1
0.8
0.6
0.4
0.2

RESULTS SQLI & XSS

Evaluation Set	Accuracy	Precision (macro)	Recall (macro)	F1-Score	Loss
Train	97%	92%	98%	94%	0.05
Validation	97%	92%	98%	94%	0.05
Test	97%	92%	98%	95%	0.05
NeuroAudit's custom dataset	76%	49%	48%	48%	-
SQLi-LAB	54%	39%	36%	37%	-

RESULTS


Normalized Confusion Matrix SQLI&XSS on test
True Label
Predicted Label
0
1
2
0.97
0.02
0.01
0.01
0.99
0.00
0.02
0.00
0.98
0.8
0.6
0.4
0.2

CONCLUSION

NeuroAudit offers a model that benefits all users of the PHP language, promoting the creation of vulnerability-free code and thus improving their cybersecurity.

Illustrate the considerable capacity of NeuroAudit model to enhance the performance and precision of identifying software vulnerabilities in PHP source code files.

FUTURE WORK

Enhance NeuroAudit custom dataset

support more programming languages

Investigate a wider range of vulnerabilities

THANK YOU